

Student Ransomware Playbook

A plain-language guide for college and university students. How to spot phishing, protect your accounts and coursework, and know what to do if something goes wrong.

Created by Joshua Gerstenfeld and Scott Jacques with support from the CrimRxiv Consortium. Open access. Code MIT-licensed; content CC BY 4.0. Live site: <https://crimconsortium.github.io/student-ransomware-playbook/>

Protect yourself (before anything goes wrong)

- Turn on multi-factor authentication (MFA) for your campus account, email, and any system holding your records.
- Use a password manager and a unique password for your campus identity. Don't reuse it on other sites.
- Keep your laptop, phone, and browser updated. Install updates within 7 days of release.
- Back up your coursework to campus cloud storage (and a second copy where allowed). Don't rely on a single drive.
- Save the IT help desk and security team contact info in your phone before you need it.
- Complete any phishing or security training the campus offers. Even short modules build real skill.
- Review your account recovery options (backup email, phone) so an attacker can't reset your password.

Phishing red flags

- Urgency: "Your account will be locked in 24 hours."
- A login link in the message — type your campus URL into the browser yourself.
- Sender domain close but not exact (e.g., support@my-college.edu.help).
- Unexpected attachments — zip files, OneNote files, HTML "invoices."
- Offers too good to be true: surprise scholarships, refunds, high-paying student jobs.
- MFA prompts you didn't trigger. Never approve a prompt you didn't start.

And sometimes there are no red flags. A real account from someone you actually know — a friend, a professor, your RA, the campus help desk — can be compromised and used to send phishing. Same name, same email address, normal-looking signature. If a message asks you to click a link, log in somewhere, pay something, share an MFA code, or move money, treat the request with suspicion — not just the sender. Verify out-of-band: text or call the person on a number you already had, or walk over.

If something goes wrong

In the moment

- If a message, login page, or pop-up looks suspicious, stop. Don't click, don't enter credentials.
- If you already clicked or entered a password, change that password from a different device and report it now.
- If your device is acting strange (files renamed, ransom note, unexpected encryption), disconnect it from Wi-Fi and any cables, leave it powered on, and contact IT.
- Forward suspicious emails using the campus 'Report Phishing' button or as an attachment to the security team.
- Don't try to 'fix' a suspected infection yourself. Don't pay a ransom on a personal device. Call IT.
- Follow official guidance from the campus emergency channel. Ignore unverified rumors on social media.

After the dust settles

- Change passwords for any account that may have been exposed and review login history.
- Re-enable backups and confirm your important files are still recoverable.
- Tell classmates and roommates what you saw. Phishing campaigns usually target many students at once.
- Attend any post-incident briefings. They teach you the exact lure that worked so you can spot the next one.

Quick checklist

- MFA is on for my campus email and student portal.
- I use a password manager (or at least a unique password for school accounts).
- My laptop and phone install updates automatically.
- I have at least one backup of my coursework outside the device I use daily.
- I know how to report a phishing email on my campus.
- The IT help desk number is saved in my phone.
- I've reviewed my account recovery email and phone in the last 6 months.

Drills

18 short incident rehearsals. Some are anchored in a simulated dorm room you can click around; the rest are off-screen patterns (fake login page, MFA fatigue, job and financial-aid scams, lost or stolen devices). Each drill has branching choices and a short after-action review. Play the interactive version at crimconsortium.github.io/student-ransomware-playbook/drills.html and earn a printable Cyber-Smart Student certificate after finishing them all. The drills are listed below for quick offline reference.

01. Your laptop is encrypted before finals

You sit down to finish your paper. Instead of your desktop you see a black screen with red text: 'All your files are encrypted. Pay 0.05 BTC within 48 hours or lose them.' Your draft, your notes, and your reference manager library all appear gone.

- Keep cloud backup turned on for school work (OneDrive, Google Drive, iCloud, or Dropbox).
- Know my campus IT help desk number. Save it in my phone now.
- Don't plug anything into a suspect device.
- If a device is acting weird, disconnect from Wi-Fi first; don't power off.

02. Your roommate clicked a sketchy link

Your roommate calls you over. Their laptop has a full-screen alert with a phone number and a loud voice telling them to 'call Microsoft to remove the virus.' They want to call it.

- Help one friend turn on MFA this week.
- Know how to force-quit a browser on the OS I use.
- Treat any phone-number popup as a scam.

03. Your club treasurer account was compromised

You're the treasurer of a student club. Members are screenshotting Venmo and Zelle requests from your account name asking for 'final dues this week only.' You didn't send them. When you check your phone, you're logged out.

- Use a password manager for any shared club account.
- Turn on MFA on every payment app I use.
- Make sure the club has at least two officers who can lock an account out.
- Keep a written incident timeline if something goes wrong.

04. A new Wi-Fi network appears in the dorm

You're studying in your room and your laptop says the campus Wi-Fi is slow. You scan the available networks and see a new one: 'DormWiFi-Free-Faster,' with full signal and no password.

- Only join Wi-Fi networks whose names I recognize.
- Never type credentials into a captive portal that looks unfamiliar.

- Report rogue SSIDs to campus IT.

05. The shared printer asks for a code

You walk to the floor printer to grab your paper. The screen says, 'Firmware update required. Sign in with your campus account to authorize.' Other students are waiting in line.

- Never type my campus password into a printer, kiosk, or vending machine.
- Report odd-looking prompts on shared hardware to housing or IT.

06. Your cloud drive shared everything publicly

You open Google Drive (or OneDrive) and see that a top-level folder named 'Schoolwork' now has a sharing badge: 'Anyone with the link can view.' You did not change that.

- Lock my laptop whenever I walk away from it.
- Audit my cloud drive sharing once a semester.
- Use MFA on the account my school work lives in.

07. You lost your phone, and it has all your MFA

You realize you don't have your phone. Last time you saw it was an hour ago. Your phone has the authenticator app for your campus account, your bank, your email, and your password manager.

- Save MFA backup codes somewhere offline.
- Know how to use Find My Device / Find My iPhone before I need it.
- Have my carrier's number saved in two places (phone + paper).

08. Someone hands you a USB stick at a meeting

At a student-org meeting, a visiting speaker offers their slides on a USB stick. 'Just plug it in, we're running short on time.' The stick has no label.

- Never plug in a USB stick I didn't buy myself.
- Ask for files via email or a cloud link instead.
- Disable USB auto-run on my laptop.

09. A 'fire safety inspection' email from your RA

Your inbox has a message: 'Mandatory fire safety inspection. Confirm your room number within 1 hour to avoid a \$100 fine.' The sender looks like your RA's name, but the address is a Gmail you've never seen, not the campus one.

- Always check the full sender domain, not just the display name.
- When in doubt, verify out-of-band.
- Report suspicious emails to my campus phishing inbox.

10. The 'IT Help Desk' email

It's 11:47 PM. Your paper's due tomorrow. An email shows up: 'ACTION REQUIRED: Your campus account will be deleted in 24 hours.' It tells you to click a link and 'verify your identity' or you'll lose your coursework. The sender has your school's name in it, but the part after the @ isn't quite right.

- Hover the sender and the link before I click.
- Report suspicious emails through my campus phishing button or inbox.
- If I might have typed credentials, change my password from a different device.

11. The Canvas link that wasn't

Your TA shares 'a quick poll for Friday's class' in the course Discord. The link opens a page that looks like your school's Canvas login, but the URL in the address bar reads 'canvas-myschool-edu.app/auth'.

- Verify suspicious links out-of-band (text, in-person, official email).
- Type campus URLs myself or use my own bookmark; don't trust links sent to me.
- Report the original link so IT can take it down for everyone else.

12. The 2 AM MFA prompts

At 2:11 AM your phone buzzes with an MFA push notification. 'Approve sign-in?' You ignore it. Two minutes later, another. By 2:20 AM you've had nine prompts in a row. You're not trying to sign in to anything.

- Deny any MFA prompt I didn't start.
- After a push-bomb, change my password and sign out all sessions.
- Enroll in phishing-resistant MFA (passkey or hardware key) if my school offers it.

13. The 'paid research assistant' DM

Someone DMs you on LinkedIn claiming to be a visiting professor in your department. They're 'urgently hiring a paid research assistant for remote work: \$40/hr, 10 hrs/week.' They ask for your personal email so they can send a contract, and request you Venmo \$75 for 'software setup' that they'll reimburse with your first paycheck.

- Treat any 'upfront fee,' off-platform contact, or too-good-to-be-true rate as a job scam.
- Verify a recruiter's identity through the company's real website, not their DM.
- Report fake job posts to the platform and to my campus career center.

14. 'Verify your FAFSA refund'

You get a text: '[University] Financial Aid: Your refund of \$1,432.18 is on hold. Verify your bank info within 12 hours to prevent reversal: [hxxps://fin-aid-portal-myschool.com](https://fin-aid-portal-myschool.com)'.

- Check my student portal directly; never trust a financial-aid link in a text.
- Call the financial-aid office using a number from the school's real website.
- Treat 'verify within X hours' urgency as a phishing signal.

15. The club Google Drive looks weird

You're the secretary of a campus club. This morning, your shared Google Drive shows two folders missing, several files renamed to 'encrypted-by-...' style names, and a new 'share' to an external Gmail address you don't recognize. The club president is in class.

- Revoke unknown shares immediately, then restore from version history.
- Change the owner account's password and sign out all sessions after any club-account weirdness.
- Loop in campus IT and the club's faculty advisor on shared-account incidents.

16. Stolen laptop at the library

You stepped away for two minutes to refill a water bottle. Your laptop is gone. It was unlocked. Your campus email, Canvas, and a draft of your thesis were open.

- Sign out of campus accounts everywhere and change my password the moment a device is missing.
- File a police or campus-security report; use Find My to mark the device lost.
- Keep full-disk encryption (FileVault or BitLocker) on so a thief is mostly facing a brick.

17. The roommate who wants 'just one login'

Your roommate asks if they can borrow your campus login to access the library's paid databases for an essay due tomorrow. They say theirs 'glitched out' and they don't want to wait for the help desk to open.

- Never share my campus password, even with a roommate, even "just this once."
- Help friends use 24/7 self-service password reset or the after-hours help desk instead.
- Reach paywalled articles through the library, Google Scholar, or publisher 'read-only' links.

18. The unmarked USB stick

You find a USB stick on the desk in a group study room you just booked. No label, no name, no return-address sticker. You wonder if it's a classmate's lost drive.

- Never plug an unknown USB stick into any device I care about.
- Drop found USB sticks at the library lost-and-found or campus IT.
- Don't use lab PCs as a 'sandbox' for unknown drives; they're on the campus network.

FAQ

What even is ransomware, in plain terms?

Software that locks up your files (and usually steals copies first) so someone can charge you to unlock them, or to not leak them. As a student you mostly see the way in: phishing emails, fake login pages, and account takeovers.

Why should I care? Isn't this an IT problem?

Your account is the easiest way in. Universities have documented student accounts being taken over by phishing, then used to send more phishing to classmates from a trusted address, and to reset passwords or change account-recovery settings so attackers keep access even after the original password is changed. A single careless click can affect your grades, financial aid, and the people around you.

I think I clicked a phishing link. What now?

Stop using the device. From a different device (your phone is fine), change the password for the affected account, then call the campus IT help desk. Keep the original message. IT may need it. Speed matters more than embarrassment.

My laptop is showing a ransom note. What should I do?

Don't pay anything. Disconnect from Wi-Fi and unplug any cables, but leave the device powered on (forensics may need volatile memory). Call campus IT right now. Don't try to 'fix' it yourself.

Is the campus going to discipline me if I report a mistake?

Many campuses encourage honest reporting and treat accidental clicks differently from intentional misconduct. They need the data to defend everyone. Check your campus policy, but in general the cost of not reporting is worse than the cost of reporting.

Should I use a personal device for schoolwork?

Generally fine if it's up to date, has MFA on your campus account, and you don't pirate software on it. Some courses or programs (e.g., clinical, legal, research with sensitive data) require institution-managed devices. Check your syllabus.

Is MFA actually worth the hassle?

Yes. Multi-factor authentication is one of the most important things you can do to protect an account, and CISA recommends it for everyone. Phishing-resistant MFA (FIDO2 / passkeys / hardware keys like YubiKey) is the strongest form because the credential is bound to the legitimate site. Enable it wherever your campus offers it.

Is public Wi-Fi at the coffee shop dangerous?

Less than it used to be. Most sites and apps use HTTPS by default. Still a good idea to avoid logging into your campus account from networks you don't trust, and to use your campus VPN if your school provides one.

Can this site substitute for legal advice?

No. This is a plain-language educational summary. Specific obligations under FERPA, state breach laws, or your campus policies depend on your situation. Talk to your IT help desk, dean of students, or campus counsel.

Glossary

After-action review (AAR) — A structured, blameless review held after an incident to capture what happened, what worked, what didn't, and what to change. Produces a written report with tracked actions.

Backups (immutable / offline) — Copies of data that can't be altered or deleted by a normal admin (immutable) or are physically disconnected (offline). Critical for ransomware recovery.

CISA — U.S. Cybersecurity and Infrastructure Security Agency. Publishes the #StopRansomware guide and maintains free resources for higher education.

Command and control (C2) — Infrastructure attackers use to communicate with malware on compromised systems. Blocking C2 helps stop ongoing attacks.

Containment — Steps that stop an attack from spreading further: isolating hosts, disabling accounts, revoking sessions, blocking outbound traffic.

Decryption key — The key needed to reverse ransomware encryption. May or may not be supplied by attackers after payment; sometimes published by law enforcement.

Detection — Identifying that an intrusion or attack is occurring or has occurred, ideally before damage is done.

Endpoint Detection and Response (EDR) — Software that monitors laptops, desktops, and servers for malicious behavior and supports investigation and response.

FERPA — Family Educational Rights and Privacy Act (U.S.). Governs the privacy of student education records and shapes notification obligations.

FIDO2 / WebAuthn — Phishing-resistant authentication standards. Hardware keys and platform authenticators (Touch ID, Face ID, Windows Hello) implement them.

Incident Commander — The single person responsible for directing the response during an incident, regardless of normal seniority.

Indicator of Compromise (IOC) — An observable artifact (file hash, IP, domain, behavior) that suggests a system has been attacked.

MFA / Multi-factor authentication — Requiring more than a password to sign in, typically a code or hardware key. Phishing-resistant MFA (FIDO2/WebAuthn) binds the credential to the real site, so it cannot be replayed on a fake login page.

MFA fatigue — Attack where an attacker repeatedly triggers MFA prompts hoping the user approves one out of frustration.

NIST — U.S. National Institute of Standards and Technology. Publishes the Cybersecurity Framework and SP 800-61 for incident response.

Phishing — Deceptive messages (email, SMS, voice, web) that trick users into entering credentials, running malware, or approving fraudulent transactions.

Ransomware — Malware that encrypts files and/or steals data, then demands payment to restore access or to prevent publication.

RDP — Remote Desktop Protocol. Frequently abused by attackers when exposed to the internet without strong controls.

Segmentation — Dividing a network into zones so a compromise in one area can't spread freely to others.

Tabletop exercise — A facilitated discussion-based drill where leaders walk through their response to a hypothetical incident.

Third-party risk — Risk introduced by vendors, SaaS providers, and contractors. Recent higher-ed ransomware impact has been driven heavily by exploited third-party software.

Sources

CISA Secure Our World — Plain-language consumer guidance from the U.S. Cybersecurity & Infrastructure Security Agency on MFA, phishing, passwords, and updates.

<https://www.cisa.gov/secureourworld>

CISA #StopRansomware — U.S. CISA hub of ransomware guidance, including how to report an incident.

<https://www.cisa.gov/stopransomware>

National Cybersecurity Alliance — StaySafeOnline — General-public cybersecurity basics, including phishing, passwords, and account safety.

<https://staysafeonline.org/online-safety-privacy-basics/>

EDUCAUSE: Cybersecurity Awareness for College Students — Higher-ed-focused student safety tips from Purdue/EDUCAUSE.

<https://library.educause.edu/resources/2020/9/cybersecurity-awareness-for-college-students-7-things-to-do-now>

Federal Trade Commission — Identity Theft and Online Security — U.S. FTC guidance for individuals on online privacy, scams, and recovering from identity theft.

<https://consumer.ftc.gov/identity-theft-and-online-security/online-privacy-and-security>

FBI Internet Crime Complaint Center (IC3) — Where U.S. individuals and institutions can report cyber incidents to the FBI.

<https://www.ic3.gov/>

Higher Ed Dive: Ransomware in Education, H1 2025 — Reporting on the scale and trends of ransomware affecting colleges and schools.

<https://www.highereddive.com/news/ransomware-attacks-education-jump-23-percent-h1-2025/754011/>

University of Utah ISO: Students Face Increasing Phishing and Other Cyberattacks (2021) — University of Utah Information Security Office advisory documenting compromised student accounts and attackers using socially-engineered information to reset passwords and maintain access.

<https://attheu.utah.edu/announcements/students-face-increasing-phishing-and-other-cyberattacks/>

The Maroon Tiger: Several Morehouse students fall victim to phishing emails (2025) — Student newspaper reporting, with Morehouse College ITS confirmation, of compromised student accounts being used to send phishing to other students (fake job, work-study, and direct-funding lures).

<https://maroontigermedia.com/2025/08/phishing-morehouse-emails-student-hacking/>

Tischer et al., 'Users Really Do Plug in USB Drives They Find' (IEEE Security & Privacy, 2016) — University of Illinois / Google research demonstrating that 45-98% of dropped USB drives were plugged in by finders, with first drives connected in under six minutes.

<https://research.google/pubs/users-really-do-plug-in-usb-drives-they-find/>

No More Ransom Project — Europol-backed clearinghouse of legitimate, free ransomware decryption tools. Use only at the direction of IT or law enforcement, never as a first response.

<https://www.nomoreransom.org/>